

정보 자산 위험 관리 절차서

1. 목적

본 절차서는 (주)세진 임직원의 증가하는 사이버 침해 사고로부터 정보 자산을 보호하기 위한 체계적인 문서 관리 방안을 제시한다. 특히, 전자문서 통제는 (주)세진의 정보 자산 위험 관리 프로세스 내에서 위험 처리 방안의 핵심적인 실행 방안으로 적용된다. (주)세진의 모든 정보자산(전자문서 및 물리적 문서 포함)에 대한 안전한 관리 및 보호를 목표로 한다.

2. 적용범위

본 절차서는 (주)세진의 모든 임직원이 생성, 관리, 활용하는 전자문서 및 물리적 문서를 포함한다. (주)세진의 정보 자산 위험관리 프로세스 4단계(자산 식별, 위험 분석, 위험 평가, 위험 처리)에 따라 문서의 중요도와 위험 수준을 평가하고, 적절한 보안 통제 방안을 적용하여 체계적으로 관리한다.

3. 용어의 정의

1. **정보 자산**: 조직이 보유하고 있는 데이터나 정보를 포함한 유/무형의 자산
2. **문서**: 회사 내에서 기록되고 승인된 문서
3. **전자문서**: 컴퓨터 등 정보처리시스템으로 작성, 송신·수신 또는 저장된 문서형식의 자료
4. **물리적 문서**: 종이 등 실체가 있는 형태로 존재하는 문서
5. **통제본**: 수정이나 보완이 필요할 때 교체해야 하는 문서
6. **비통제본**: 수정이 되더라도 교체가 필요하지 않은 문서
7. **유효본**: 승인 완료 후 폐기되지 않은 최신 문서
8. **자료(Data)**: 외부에서 발행된 문서로, 발행 기관의 통보 없이 수정이 불가능한 문서
9. **기록(Records)**: 업무 수행의 결과물로, 수정이 불가하며 증거용으로 사용되는 문서
10. **위험(Risk)**: 위협이나 취약점을 이용하여 자산에 피해를 줄 가능성
11. **위협(Threat)**: 자산에 악영향을 줄 수 있는 사건 및 행위
12. **취약점(Vulnerability)**: 위협이 발생하기 위한 조건이나 상황
13. **정보보호 관리체계(ISMS)**: 정보 자산의 기밀성, 무결성, 가용성을 실현하기 위한 절차와 과정을 체계적으로 수립, 문서화하고 지속적으로 관리·운영하는 체계

4. 책임과 권한

본 절차서의 책임·권한 체계는 첨부된 **기업 정보자산 관리 조직도** 표준 역할을 기반으로 **세진 정보자산 관리 조직도(4계층)**의 내용을 반영하여 작성되었다. 각 계층은 상위 → 하위 순으로 보고·통제 관계를 가진다. 책임 및 권한은 ISMS 등 법규 요구사항을 충족하기 위하여 정의되었으며, 정보자산관리자, 정보자산담당자의 직책은 겸임할 수 있다.

계층	직책	주요 책임	세부 책임
1단계	대표이사 (CEO)	전사 정보보안 정책 최종 승인 및 자원 할당	- 정보보호 예산 승인 - 중요 보안정책 의사결정 - 보안 사고 최종 책임
2단계	부사장	전사 정보자산 관리 운영 총괄 및 본부 간 협력 조정	- 조직 간 정책 실행 관리 - 위험 대응 우선순위 조정
2단계	정보보호최고책임자	정보보호 전략 수립 및 조직·예산 운영 총괄	- 정보보호 계획 수립 - 보안 감사·위험평가 총괄 - 보안 사고 대응 총괄
3단계	정보보호 담당자 (관리·물리·기술)	정보보호 세부 정책 수립 및 실행	- 관리·물리·기술 영역별 통제 운영 - 보안 솔루션 운영 - 시설 보안·출입 통제
3단계	본부장 (본부정보자산책임자)	본부별 정보자산 관리 총괄	- 본부 정책 수립 - 부서 현황 점검 - 본부 보안 교육 계획 - 본부별 자산관리 정책·계획 수립
4단계	부서장 / 팀장 (부서 정보자산관리자)	부서 단위 정보자산 관리 감독	- 부서 관리 계획 수립 - 정보자산관리자/담당자 지정 - 정책 시행 감독
5단계	정보자산관리자	부서 정보자산 관리 실무 총괄	- 정보자산 목록·등급 관리 - 생명주기 및 접근권한 관리 - 정기 점검 보고
6단계	정보자산담당자	정보자산 식별·등록·변경 처리 및 1차 보안 점검	- 신규 자산 등록 - 변경사항 업데이트 1차 사고 대응
7단계	일반 사용자	정보자산 적절 사용 및 보안 정책 준수	- 보안 절차 준수 - 사고 발견 시 즉시 보고

보고 체계: 정보자산담당자/팀장 → 정보자산관리자 → 부서장 → 본부장 → CISO/부사장 → CEO

보고 주기(권장): 팀/실장 주간, 본부장 월간, CISO/부사장 분기, CEO 반기

4.1 정보자산 관리 조직도

문서 관리 절차의 각 책임·권한 체계가 실제 조직 계층과 정확히 매핑되도록 하기 위해 본 절차서에 전문을 포함한다. 부서단위의 상세내역은 별첨. 세진 정보자산 관리조직도를 참고한다.

- 별첨 : [세진 정보자산 관리조직 및 운영지침](#)
- 조직도 트리뷰

대표이사 (CEO) - 경영리더 김민규

└─ 부사장 - 경영리더 홍득희

└─ 연구개발본부(연구개발본부 정보자산책임자) - 상무 김동국

└─ 원가영업실 - 실장 조효제

└─ 원가영업1팀(정보자산관리자) - 팀장 조효제

└─ 원가영업2팀(정보자산관리자) - 팀장 조준식

└─ 개발1팀(개발1팀 정보자산관리자) - 팀장 곽병철

└─ 개발2팀(개발2팀 정보자산관리자) - 팀장 이효진

└─ 설계팀(설계팀 정보자산관리자) - 팀장 김종훈

└─ 외주관리팀(외주관리팀 정보자산관리자) - 팀장 백만기

└─ 품질본부(품질본부 정보자산책임자) - 상무 김영태

└─ 신차품질팀(신차품질팀 정보자산관리자) - 팀장 이희철

└─ 품질보증팀(품질보증팀 정보자산관리자) - 팀장 임경환

└─ 품질경영팀(품질경영팀 정보자산관리자) - 팀장 임철재

└─ 경영지원본부(경영지원본부 정보자산책임자) - 상무 이성영

└─ 구매팀(구매팀 정보자산관리자) - 팀장 신정현

└─ 재경팀(재경팀 정보자산관리자) - 팀장 천성웅

└─ 총무팀(총무팀 정보자산관리자) - 담당 손명천

└─ 전산팀(전산팀 정보자산관리자) - 담당 권세창

└─ 생산본부(생산본부 정보자산책임자) - 상무 최인규

└─ 생산1실 - 실장 박청식

└─ 생산1팀(생산1팀 정보자산관리자) - 팀장 김덕진

└─ 생산기술팀(생산기술팀 정보자산관리자) - 팀장 류동완

└─ 생산2실 - 실장 안준우

└─ 생산2팀(생산2팀 정보자산관리자) - 팀장 이충호

└─ 물류팀(물류팀 정보자산관리자) - 팀장 최현오

└─ 노무팀 - 팀장 김영빈

└─ 정보보호최고책임자 (CISO) - 상무 이성영

└─ 관리보안담당자 - 책임매니저 손명천

└─ 물리보안담당자 - 책임매니저 손명천

└─ 기술보안담당자 - 책임매니저 권세창

4.2 보고 체계 및 주기

구분	보고 대상	보고 주기	비고
팀장·실장 → 본부장	팀/실 단위 정보자산 현황, 사고 및 개선 사항	주간	주간 회의·보고서
본부장 → CISO/부사장	본부별 종합 현황, 위험 분석 결과	월간	월간 경영회의
CISO/부사장 → CEO	전사 보안 성과, 중요 위험·예산 요청	분기	분기 경영진 리뷰

협력 체계: 팀/실장 협의체(매월 1회), 본부장 협의체(분기), 경영진 위원회(반기)

보안 교육: 계층별 맞춤형 교육(월 1회 이상)

권한 관리: 각 계층별 접근권한 원칙을 준수하고 주기적 권한 재검토 실시

4.3 표준 역할 대비 개선 검토 사항

개선 검토 사항은 지속적으로 단계적으로 이행하며, 이행 결과는 **본 절차서 7. 이행 점검** 단계에서 확인·반영한다.

- 별첨 : [표준 한국기업 정보자산 관리 조직도](#)

표준 역할 (Template)	현행 조직 반영 여부	검토 항목	검토 조치 제안
정보자산담당자	부족	팀/실 단위 실무 담당자 지정 필요	각 팀에서 1명 이상 지정 → CISO 승인 후 자산관리시스템 등록
일반 사용자(7단계)	암묵적	정책 준수 의무 명시 부족	모든 임직원 대상 책임 명문화, e-러닝 교육 포함
보안 감사 기능	부족	내부 정보보안 감사 및 점검 역할 미정	품질본부 산하 '정보보안 감사팀' 신설 또는 외부 감사 연 2회
권한·접근 통제	필요	정기 재검토 주기 명확성 미흡	연 1회 이상 권한 일괄 점검 (각 부서장 책임)

5. 정보자산 위험관리절차

5.1 정보자산 분류 및 중요도 평가 (1단계)

목적: 기업이 보유한 중요 자산을 보호하기 위해 우선 보호 대상을 식별한다.

5.1.1 자산 조사 및 식별

1. 전자정보, 문서, 소프트웨어, 시설, 하드웨어, 지원설비, 인력 등 다양한 유형의 자산을 식별한다.
2. 문서는 중요한 정보 자산 유형 중 하나로 분류하여 관리한다.

5.1.2 분류 및 등록

1. 식별된 자산을 유형적 자산(시스템, 인력, 물리적)과 무형적 자산(데이터/소프트웨어)으로 분류한다.
2. 문서는 무형적 자산에 해당하며, 중요도가 낮은 자산은 세부 목록 작성을 생략할 수 있다.
3. 자산 분류 기준표 작성 시 식별번호, 자산 유형/그룹, 자산명, 설명, 소유자, 중요도를 명시한다.

5.1.3 중요도 평가

1. 자산의 가치를 평가하고 등급을 산정한다.
2. 주요 기준은 다음과 같다:
 - 기밀성(Confidentiality): 정보에 대한 접근을 인가된 사용자로 제한하는 특성
 - 무결성(Integrity): 정보의 정확성과 완전성을 보장하는 특성
 - 가용성(Availability): 인가된 개체가 요구할 때 접근 가능하고 사용 가능한 특성
 - 유출 영향도(Effluent Impact): 정보 유출 시 발생할 수 있는 피해 정도
3. 4개 항목에 대한 배점(총 10점 만점)과 점수 구간에 따른 등급 분류 기준을 적용한다:
 - 극비(8~10점): 유출 시 회사 존립에 위협이 될 수 있는 정보
 - 대외비(6~7.9점): 유출 시 회사에 상당한 재산/신용 손실을 줄 수 있는 정보
 - 일반(4~5.9점): 공개되어도 큰 영향이 없는 정보
 - 관리제외(4점 미만): 공개가 가능한 정보

5.2 위험 분석 (2단계)

목적: 식별된 자산에 대한 위협, 취약성, 위험을 도출하고 분류하여 자산 가치에 대한 잠재적 손실 영향을 분석한다.

5.2.1 위험 구성 요소 정의

1. 위협(Threat): 취약성을 활용할 수 있는 가능성
2. 취약성(Vulnerability): 악용당할 수 있는 결점 또는 안전장치의 부재
3. 위험(Risk): 취약성 악용으로 인한 잠재적 손실 가능성

5.2.2 컨텍스트 분석

1. 기업 내·외부에서 발생하는 이슈, 이해관계자, 법적 요구사항 등을 통해 보안 위협 요소를 식별한다.
2. 컨텍스트 분석을 통해 조직 환경에 특화된 위험 요소를 도출한다.

5.2.3 위험 및 취약성 도출

1. 자산에 대하여 존재하는 위협과 취약성을 분석한다.
2. 시나리오 기반 위험 분석을 통해 누가, 왜, 어디서, 언제, 무엇을, 어떻게 하여 어떤 결과와 비즈니스 영향이 발생하는지를 구체화한다.

5.3 위험 평가 (3단계)

목적: 분석된 위험의 수준을 수치화하고, 미리 설정한 목표 위험 수준과 비교하여 각 위험의 대응 여부와 우선순위를 결정한다.

5.3.1 위험도 산출

1. 적용 범위(자산), 발생 가능성, 파급 효과 등 비즈니스 영향 관점에서 위험도를 수치화한다.
2. 위험도 = 적용 범위(자산) × 발생 가능성 × 파급 효과 산식을 적용한다.
3. 중요도, 파급효과, 발생가능성을 조합한 평가 기준을 사용할 수 있다.

5.3.2 수용 가능한 수준 결정 (DoA: Degree of Acceptance)

1. 조직이 수용할 수 있는 위험 수준(DoA)을 설정한다.
2. 경영진의 승인을 통해 DoA 기준을 확정한다.

5.3.3 대응 결정

1. 평가된 위험도가 DoA 이상인 경우 비용을 들여 대응한다(위험 감소).
2. DoA 이하인 경우 잔여 위험으로 관리하거나 잠정적으로 대책을 보류할 수 있다(위험 수용).
3. 최종 대응 방안은 경영진의 결정을 통해 확정한다.

5.4 위험 처리 통제 방안 (4단계)

목적: 위험 평가를 통해 결정된, 수용 가능한 수준 이하로 낮춰야 할 위험에 대해 정보 보호 대책을 선정한다.

5.4.1 대응 전략 선정

1. 위험의 성격 및 비용-효과성을 고려하여 다음 전략 중 적절한 것을 선택한다:
 - 위험 회피: 위험이 있는 활동 자체를 중단
 - 위험 전가: 제3자에게 위험 이전(보험, 아웃소싱 등)
 - 위험 감소: 위험 수준을 낮추기 위한 통제책 구현
 - 위험 수용: 위험을 받아들이고 모니터링
2. 각 전략별 구현 방안과 예상 효과를 분석한다.

5.4.2 보호 대책 적용

1. 위험 감소를 위해 보안 대책을 적용하며, 관리적, 물리적, 기술적 영역의 통제 정책을 활용한다.
2. 선정된 보호 대책의 구현 일정과 담당자를 지정한다.

5.4.3 전자문서 통제 방안

관리적 통제 방안

- 위험도가 높은 문서 유형 대상 유출 통제 세부 기준을 마련한다.
- 문서 작성 애플리케이션 암호 설정 기능을 활용한다.
- 파일/폴더 접근 권한 관리를 강화한다(파일 서버, NAS).
- 중요 시스템 파일 다운로드 권한 통제를 강화한다(ERP, PLM, DMS 등).
- 데이터베이스 암호화를 적용한다.

기술적 통제 방안

- 파일 암호화(DRM) 솔루션 도입을 검토한다.
- 정보 유출 방지(DLP) 솔루션 도입을 검토한다.
- 문서 중앙화 솔루션 도입을 검토한다.

6. 관련 가이드 및 양식

6.1 자산 분류 기준표 및 자산별 중요도 평가 양식

- 식별번호, 자산 유형, 자산명, 소유자, 중요도 등급을 기록한다.
- 작성가이드 : [별첨 A. 문서 유형 분류 및 중요도 평가 작성 가이드](#)를 참조한다.
- 작성예시 : [자산 분류 기준표 작성 예시](#)
- 작성예시 : [자산별 중요도 평가 작성 예시](#)
- 첨부 : [04-자산분류기준표](#), [05-자산별중요도평가](#)

6.2 정보 중요도 참고 기준표

- [영업비밀 등급 자가확인 서비스](#)
- [영업비밀 등급 조회](#)
- [영업비밀 등급 산출](#)
- [영업비밀 등급분류 가이드](#)

6.3 취약성 및 위협 평가 목록

- 자산별 위협 요소와 취약성을 체계적으로 기록한다.
- 작성가이드 : [별첨 B. 위험 분석 및 평가 작성 가이드](#)를 참조한다.
- 작성예시 : [취약성 및 위협 평가 목록 작성 예시](#)
- 첨부 : [06-취약성위협평가목록](#)

6.4 시나리오 기반 위험 분석표

- 위험 시나리오별 상세 분석 내용을 기록한다.
- 작성가이드 : [별첨 B. 위험 분석 및 평가 작성 가이드](#)를 참조한다.
- 작성예시 : [시나리오 기반 위험분석 작성 예시](#)
- 첨부 : [07-시나리오기반위험분석표](#)

6.5 자산별 위험 평가 결과표

- 위험도 점수, 등급, 대응 방안을 기록한다.
- 작성가이드 : [별첨 B. 위험 분석 및 평가 작성 가이드](#)를 참조한다.
- 작성예시 : [자산별 위험 평가 결과 작성 예시](#)
- 첨부 : [08-자산별위험평가결과표](#)

6.6 위험 처리 방안 결정 양식

- 대응 전략, 상세 방안, 고려사항을 기록한다.
- 작성가이드 : [별첨 C. 통제 방안 선정 가이드](#) 를 참조한다.
- 작성예시 : [위험 처리 방안 결정 작성 예시](#)
- 첨부 : [09-위험처리방안결정양식](#)

6.7 핵심 관리 대상 전자문서 선정 및 통제 방안 적용 이력 관리 양식

- 전자문서별 적용된 통제 방안과 이력을 관리한다.
- 작성가이드 : [별첨 C. 통제 방안 선정 가이드](#) 를 참조한다.
- 작성예시 : [핵심 문서 통제 이력 관리 작성 예시](#)
- 작성예시 : [문서 관리 점검 체크 리스트 작성 예시](#)
- 첨부 : [10-핵심문서통제이력관리양식](#), [14-문서관리점검체크리스트](#)

7. 이행 점검

본 절차서의 이행 상황은 2025년 정보자산 위험관리 이행 점검의 주요 확인 사항에 따라 정기적으로 점검하며, 점검 결과를 바탕으로 절차서를 지속적으로 개선한다.

1. **점검 주기:** 연 1회 정기 점검, 필요 시 수시 점검
2. **점검 주체:** 정보보안팀
3. **점검 방법:** 문서관리 점검체크리스트 활용
4. **점검 항목:**
 - 문서 분류 적절성
 - 중요도 평가 수행 여부
 - 위험 평가 시행 여부
 - 통제 방안 적용 현황
 - 관련 교육 실시 여부
5. **개선 조치:** 점검 결과 미흡 사항에 대한 개선 계획 수립 및 이행

8. 작성 정보

- 작성자: 권세창 (기술보안담당자)
- 소속: (주)세진 경영지원본부 전산팀
- 작성일: 2025년 6월 10일

별첨 A. 문서 유형 분류 중요도 평가 가이드

1. 문서 분류 방법

1.1 문서 유형 분류 기준

대분류	중분류	설명
경영관리	인사문서	직원의 채용, 승진, 인사발령, 교육, 평가 등 관련 문서
	총무문서	회사 규정, 시설관리, 총무 관련 문서
	기획문서	사업계획, 예산, 경영전략 등 관련 문서
	특허문서	특허, 실용신안, 상표 등 지식재산권 관련 문서
연구개발	설계도면	제품 설계 관련 도면 및 문서
	승인서류	고객 또는 인증기관 등의 승인 관련 서류
	테스트자료	제품 테스트, 검증 관련 자료
	기술문서	기술 연구, 개발 관련 문서
품질관리	품질매뉴얼	품질경영시스템 관련 매뉴얼
	측정자료	품질 측정, 검사 관련 자료
	인증문서	ISO, IATF 등 품질 인증 관련 문서
생산관리	생산계획	생산 일정, 계획 관련 문서
	작업지시서	생산 작업 지시 관련 문서
	공정관리	공정 관리, 개선 관련 문서
영업/마케팅	고객정보	고객사 정보 관련 문서
	제안서	고객사 제안 관련 문서
	계약서	판매, 공급 계약 관련 문서
	마케팅자료	홍보, 마케팅 관련 자료
구매/자재	협력업체정보	협력업체 정보 관련 문서
	구매계약	자재, 설비 구매 관련 계약 문서
	자재관리	자재 입출고, 재고 관리 관련 문서

1.2 문서 형태별 분류

형태	설명	예시
전자문서	컴퓨터 등 정보처리시스템으로 작성, 송신·수신 또는 저장된 문서형식의 자료	워드, 엑셀, PDF, CAD, 이메일 등
물리적 문서	종이 등 실체가 있는 형태로 존재하는 문서	인쇄된 보고서, 도면, 계약서 등
멀티미디어	소리, 영상 등 멀티미디어 형태의 자료	교육 동영상, 제품 사진 등
데이터베이스	구조화된 형태로 저장된 데이터	ERP, PLM 내 데이터베이스 등

2. 중요도 평가 방법

2.1 평가 기준

중요도 평가는 다음 4가지 항목을 기준으로 평가합니다:

1. **기밀성(Confidentiality)**: 정보에 대한 접근을 인가된 사용자로 제한하는 특성
2. **무결성(Integrity)**: 정보의 정확성과 완전성을 보장하는 특성
3. **가용성(Availability)**: 인가된 개체가 요구할 때 접근 가능하고 사용 가능한 특성
4. **유출 영향도(Effluent Impact)**: 정보 유출 시 발생할 수 있는 피해 정도

2.2 배점 기준

각 항목별 평가 수준과 배점은 다음과 같습니다:

항목	수준	배점	상세 설명
기밀성(C)	Extreme(E)	3.0	매우 제한된 인원만 접근 가능해야 함
	High(H)	2.3	제한된 인원만 접근 가능해야 함
	Medium(M)	1.5	부서 내 인원은 접근 가능함
	Low(L)	1.0	회사 내 인원은 접근 가능함
무결성(I)	Extreme(E)	3.0	무결성 손상 시 심각한 영향
	High(H)	2.3	무결성 손상 시 중요한 영향
	Medium(M)	1.5	무결성 손상 시 일부 영향
	Low(L)	1.0	무결성 손상 시 영향 미미
가용성(A)	Extreme(E)	2.0	24시간 즉시 사용 가능해야 함
	High(H)	1.5	업무시간 내 사용 가능해야 함
	Medium(M)	1.0	1일 이내 사용 가능해야 함
	Low(L)	0.5	지연되어도 업무에 큰 영향 없음
유출영향도(EI)	Extreme(E)	2.0	유출 시 회사 존립 위협
	High(H)	1.5	유출 시 중대한 재산/신용 손실
	Medium(M)	1.0	유출 시 일부 재산/신용 손실
	Low(L)	0.5	유출 시 영향 미미

2.3 등급 분류

4개 항목의 배점 합계에 따라 다음과 같이 등급을 분류합니다:

등급	점수 범위	설명
극비	8.0 ~ 10.0	유출 시 회사 존립에 위협이 될 수 있는 정보
대외비	6.0 ~ 7.9	유출 시 회사에 상당한 재산/신용 손실을 줄 수 있는 정보
일반	4.0 ~ 5.9	공개되어도 큰 영향이 없는 정보
관리제외	4.0 미만	공개가 가능한 정보

3. 작성 예시

3.1 자산 분류 기준표 작성 예시

자산번호	자산유형	자산분류	자산명	소유자	관리자	위치
DOC-001	정보	설계도면	신제품 설계도면(P-2025-01)	설계팀 팀장	김종훈	설계팀 서버
DOC-002	정보	승인서류	고객승인서류(현대차)	원가영업실 실장	조효제	원가영업실 서버
DOC-003	정보	품질문서	품질매뉴얼(QM-001)	품질경영팀 팀장	임철재	품질경영팀 서버

3.2 자산별 중요도 평가 작성 예시

자산번호	자산명	기밀성(C)	무결성(I)	가용성(A)	유출영향도(EI)	합계	등급 분류
DOC-001	신제품 설계도면(P-2025-01)	H 2.5	H 2.3	M 1.5	E 2.5	8.8	극비
DOC-002	고객승인서류(현대차)	H 2.3	E 3.0	M 1.0	H 2.0	8.3	극비
DOC-003	품질매뉴얼(QM-001)	M 1.5	H 2.3	M 1.5	M 1.0	6.3	대외비

4. 주의사항

1. 문서 분류 시 일관성 있는 기준을 적용하십시오.
2. 중요도 평가는 문서의 내용과 특성을 충분히 이해한 후 실시하십시오.
3. 동일한 유형의 문서라도 내용에 따라 중요도가 달라질 수 있습니다.
4. 평가 결과는 정기적으로 검토하고 필요 시 재평가하십시오.
5. 중요도 평가에는 해당 문서의 소유자와 이해관계자의 의견을 반영하십시오.

별첨 B. 위험 분석 및 평가 작성 가이드

1. 위험 분석 방법

1.1 위험 분석의 개념

위험 분석은 정보 자산에 대한 위협과 취약점을 식별하고 이로 인해 발생할 수 있는 위험을 평가하는 과정입니다.

- **위험(Risk):** 위협이 취약점을 이용하여 자산에 피해를 줄 가능성
- **위협(Threat):** 자산에 악영향을 줄 수 있는 사건이나 행위
- **취약점(Vulnerability):** 위협이 발생하기 위한 조건이나 상황

1.2 위험 분석 절차

1. **위협 식별:** 자산에 영향을 줄 수 있는 모든 위협 요소를 식별
2. **취약점 평가:** 식별된 위협이 실현될 수 있는 취약점을 분석
3. **위험 시나리오 개발:** 위협과 취약점을 조합한 구체적인 위험 시나리오 작성
4. **영향도 평가:** 위협이 실현될 경우 발생하는 비즈니스 영향 평가
5. **발생 가능성 평가:** 위협이 실제로 발생할 확률 평가

1.3 위험 유형 분류

대분류	중분류	상세 위협	예시
자연재해	천재지변	화재, 홍수, 지진	서버실 화재로 인한 데이터 손실
	환경적 요인	정전, 통신 장애	정전으로 인한 시스템 다운
인적 위협	내부자 위협	의도적 정보 유출, 파괴	퇴직 예정자의 고의적 자료 삭제
		비의도적 실수	실수로 인한 중요 파일 삭제
	외부자 위협	해킹, 침입	외부 해커의 시스템 침입
기술적 위협	시스템 장애	물리적 침입	무단 침입자의 서버실 접근
		하드웨어 오류	서버 하드디스크 고장
		소프트웨어 오류	운영체제 버그로 인한 시스템 중단
	보안 위협	악성코드 감염	랜섬웨어 감염으로 인한 데이터 암호화
		네트워크 공격	DDoS 공격으로 인한 서비스 중단

1.4 취약점 유형 분류

분류	취약점 예시	설명
물리적 취약점	출입통제 미흡	서버실, 사무실 출입 통제 부족
	환경 통제 미흡	화재 감지, 소화 시설 부족
기술적 취약점	보안패치 미적용	운영체제, 애플리케이션 보안패치 지연
	암호화 미적용	중요 데이터 암호화 처리 미흡
	접근통제 미흡	권한 관리, 인증 체계 부족
관리적 취약점	정책 부재	보안 정책, 절차 수립 미흡
	교육 부족	직원 보안 교육, 인식 제고 부족
	모니터링 부족	보안 사고 감시, 탐지 체계 부족

2. 위험 평가 방법

2.1 위험도 산출 공식

위험도는 다음 공식으로 산출합니다:

$$\text{위험도} = \text{자산 가치(A)} \times \text{위협 수준(T)} \times \text{취약성 수준(V)} \div 10$$

2.2 자산 가치 평가 기준

등급	점수	설명
극고	10	핵심 비즈니스 자산, 유출 시 회사 존립 위협
고	8	중요 비즈니스 자산, 유출 시 중대한 손실
중	6	일반 비즈니스 자산, 유출 시 일부 손실
저	4	공개 가능한 자산, 유출 시 영향 미미

2.3 위협 수준 평가 기준

등급	점수	설명
극고	10	매우 강력하고 지속적인 위협
고	8	강력한 위협, 정기적 발생 가능
중	6	보통 수준의 위협
저	4	약한 위협, 발생 가능성 낮음

2.4 취약성 수준 평가 기준

등급	점수	설명
극고	10	매우 심각한 취약점, 쉽게 악용 가능
고	8	심각한 취약점, 악용 가능성 높음
중	6	보통 수준의 취약점
저	4	경미한 취약점, 악용 어려움

2.5 위험 등급 분류

위험 등급	점수 범위	조치 방안
상 (High)	50 이상	즉각적인 위험 감소 조치 필요
중 (Medium)	30~49	계획된 위험 감소 조치 필요
하 (Low)	30 미만	위험 수용 또는 모니터링

3. 시나리오 기반 위험 분석

3.1 시나리오 작성 방법

위험 시나리오는 5W1H(Who, What, When, Where, Why, How) 방식으로 구체적으로 작성합니다:

- **누가(Who):** 위협의 주체 (해커, 내부자, 자연재해 등)
- **무엇을(What):** 공격 대상 자산
- **언제(When):** 공격이 발생할 수 있는 시점
- **어디서(Where):** 공격이 발생할 수 있는 위치
- **왜(Why):** 공격의 동기나 목적
- **어떻게(How):** 공격 방법이나 경로

3.2 시나리오 예시

시나리오: PLM 시스템 해킹 공격

- **누가:** 외부 표적공격 해커그룹
- **무엇을:** PLM 시스템 내 설계 데이터
- **언제:** 중요 프로젝트 진행 중
- **어디서:** PLM 서버, 네트워크 경계
- **왜:** 산업기밀 탈취, 사이버 테러
- **어떻게:** SQL 인젝션, 권한 상승 공격

4. 작성 예시

4.1 취약성 및 위협 평가 목록 작성 예시

번호	자산명	위협유형	위협설명	취약점	영향도	발생가능성
1	신제품 설계도면	외부 침입	외부 해커의 네트워크 침입을 통한 설계도면 탈취	방화벽 설정 미흡, VPN 보안 약함	높음	높음
2	고객승인서류	내부자 유출	승인권한을 가진 내부 직원의 고의적 정보 유출	내부 모니터링 체계 부재, 접근권한 과다	매우높음	중간

4.2 시나리오 기반 위험 분석 작성 예시

시나리오 ID	위험시나리오명	누가(Who)	왜(Why)	언제(When)	어디서(Where)	무엇을(What)	어떻게(How)	결과(Result)	비즈니스영향
SCE-001	신제품 설계도면 외부 유출	외부 해커, 경쟁사 관련자	기술 정보 탈취, 경쟁우위 확보	신제품 개발 완료 시점	설계팀 네트워크, 외부 접속	설계도면, 기술 문서	VPN 해킹, 피싱 공격	설계정보 유출, 특허 침해	신제품 경쟁력 상실, 매출 감소
SCE-002	내부자에 의한 고객정보 유출	승인권한 보유 내부 직원	금전적 이익, 개인적 불만	퇴직 전 후, 야간/휴일	사무실 내부, 원격 접속	고객 정보, 승인 서류	USB 복사, 이메일 전송	고객신뢰 실추, 법적 분쟁	고객 이탈, 손해 배상

4.3 자산별 위험 평가 결과 작성 예시

자산번호	자산명	자산가치(A)	위협수준(T)	취약성수준(V)	위험도	위험등급	대응방안
DOC-001	신제품 설계도면	9	8	7	50.4	상(High)	위험 감소 - 즉각적인 통제책 구현 필요
SW-001	PLM 시스템	10	9	8	72.0	상(High)	위험 감소 - 즉각적인 통제책 구현 필요

5. 주의사항

1. 위험 분석은 정확한 정보를 바탕으로 객관적으로 수행해야 합니다.
2. 모든 가능한 위협과 취약점을 고려하되, 현실적이고 실현 가능한 시나리오에 집중하십시오.
3. 위험 평가는 정기적으로 재검토하고 업데이트해야 합니다.
4. 평가 결과는 이해관계자들과 공유하고 검증을 받으십시오.
5. 위험 분석 과정에는 관련 부서의 전문가들이 참여해야 합니다.

별첨 C. 통제 방안 선정 가이드

1. 위험 처리 전략 선택

위험 평가 결과 식별된 위험에 대해 다음 네 가지 전략 중 하나를 선택합니다:

1.1 위험 처리 전략 유형

전략	설명	적용 상황	예시
위험 회피 (Risk Avoidance)	위험이 있는 활동 자체를 중단하거나 하지 않는 방법	위험도가 매우 높고 통제 비용이 과도한 경우	보안 위험이 높은 클라우드 서비스 사용 중단
위험 전가 (Risk Transfer)	제3자에게 위험을 이전하는 방법	전문 업체에 위탁하거나 보험 가입이 효과적인 경우	정보보안 보험 가입, 외부 보안 서비스 이용
위험 감소 (Risk Reduction)	위험 수준을 낮추기 위한 통제책을 구현하는 방법	통제 비용 대비 효과가 좋은 경우	접근 통제, 암호화, 보안 교육 등 구현
위험 수용 (Risk Acceptance)	위험을 받아들이고 모니터링하는 방법	위험도가 낮거나 통제 비용이 과도한 경우	영향이 적은 위험을 모니터링만 실시

1.2 전략 선택 기준

위험 등급	위험도	권장 전략	승인 권한
상 (High)	50 이상	위험 감소 또는 회피	CISO/CEO 승인 필요
중 (Medium)	30~49	위험 감소 또는 전가	CISO 승인 필요
하 (Low)	30 미만	위험 수용 또는 감소	보안담당장 승인 가능

2. 문서 보안 통제 방안

2.1 관리적 통제 방안

통제 유형	통제 방안	적용 대상	효과
정책 및 절차	문서 분류 기준 수립	모든 문서	문서의 중요도에 따른 체계적 관리 가능
	문서 접근 통제 정책	모든 문서	권한 없는 접근 차단
	문서 저장 및 폐기 절차	모든 문서	문서 생명주기 전반에 걸친 보안 확보
권한 관리	최소 권한 원칙 적용	모든 문서	필요한 최소한의 권한만 부여
	주기적 권한 검토	중요 문서	불필요한 권한 식별 및 제거
교육 및 인식	직원 보안 교육	모든 직원	보안 인식 제고 및 규정 준수 향상
	문서 취급 교육	중요 문서 취급자	중요 문서 취급 방법 교육
모니터링	문서 접근 로그 검토	중요 문서	비정상적인 접근 탐지
	내부 감사 수행	모든 부서	규정 준수 여부 확인

2.2 기술적 통제 방안

통제 유형	통제 방안	적용 대상	효과
암호화	문서 암호화 (DRM)	극비/대외비 문서	비인가 접근 시에도 내용 보호
	저장 매체 암호화	모바일 저장 장치	기기 분실 시에도 데이터 보호
	통신 구간 암호화	모든 문서 전송	전송 중 데이터 보호
접근 통제	사용자 인증 강화	시스템 접근	비인가 접근 차단
	다중 인증(MFA)	중요 시스템	인증 보안 강화
	IP 기반 접근 제한	내부 시스템	외부 접근 통제
유출 방지	DLP(Data Loss Prevention)	중요 문서	데이터 유출 탐지 및 차단
	워터마킹	대외비 이상 문서	유출 시 출처 추적 가능
	출력 제어	극비 문서	무단 출력 방지
모니터링	이상 행위 탐지	모든 시스템	비정상 행위 식별
	로그 수집 및 분석	모든 시스템	사고 발생 시 추적 가능

2.3 물리적 통제 방안

통제 유형	통제 방안	적용 대상	효과
출입 통제	통제구역 지정	서버실, 문서보관실	물리적 접근 통제
	출입 카드 시스템	사무실, 통제구역	인가된 인원만 출입 허용
문서 보관	보안 캐비닛	종이 문서	물리적 보관 보안 강화
	금고	극비 문서	최고 수준의 물리적 보호
문서 파기	문서 파쇄기	종이 문서	안전한 물리적 파기
	데이터 완전 삭제	저장 매체	복구 불가능한 삭제

3. 문서 보안 등급별 통제 방안

3.1 등급별 권장 통제 방안

보안 등급	관리적 통제	기술적 통제	물리적 통제
극비 (8.0~10.0점)	- 접근 권한 개별 승인 - 분기별 권한 검토 - 취급자 특별 교육 - 반출입 승인 절차	- 문서 암호화(DRM) 필수 - 워터마킹 적용 - 편집/출력 제한 - 다중 인증(MFA) - 상세 접근 로깅	- 통제구역 내 보관 - 보안 캐비닛/금고 사용 - 복사본 제한적 허용 - 파기 시 입회자 필요
대외비 (6.0~7.9점)	- 부서장 접근 승인 - 반기별 권한 검토 - 취급자 교육 - 반출 내부 승인	- 문서 암호화 권장 - 워터마킹 적용 - 접근 로깅 - 출력 제한	- 지정 장소 보관 - 보안 캐비닛 사용 - 복사본 관리 - 안전한 파기
일반 (4.0~5.9점)	- 기본 접근 통제 - 연간 권한 검토 - 일반 보안 교육	- 일반 접근 통제 - 기본 로깅 - 백업 관리	- 일반 보관 - 표준 파기 절차
관리제외 (4.0 미만)	- 최소한의 관리 - 일반 보안 교육	기본 접근 통제	일반 보관

3.2 특수 문서 유형별 추가 통제 방안

문서 유형	추가 통제 방안
고객 개인정보	- 개인정보보호법 준수 - 암호화 필수 - 접근 이력 관리 - 안전한 파기
재무/회계 자료	- 접근 권한 엄격 관리 - 변경 이력 추적 - 외부 감사 대비 관리
계약서/법적 문서	- 버전 관리 - 원본 보존 - 법적 보존 기간 준수
연구개발 자료	- 지식재산권 보호 조치 - 비밀유지 서약 - 부분 공개 통제

4. 통제 방안 구현 및 관리

4.1 구현 절차

1. **계획 수립**: 위험 평가 결과에 따른 통제 방안 선정 및 구현 계획 수립
2. **자원 할당**: 필요한 예산, 인력, 시간 등 자원 배정
3. **구현**: 선정된 통제 방안 구현
4. **테스트**: 구현된 통제 방안의 효과성 테스트
5. **교육**: 관련 직원 대상 교육 실시
6. **모니터링**: 통제 방안 운영 현황 지속 모니터링

4.2 성과 측정

측정 지표	설명	측정 방법
통제 구현률	계획 대비 구현된 통제 비율	$(\text{구현된 통제 수} / \text{계획된 통제 수}) \times 100\%$
위험 감소율	통제 적용 후 위험도 감소 비율	$(\text{적용 전 위험도} - \text{적용 후 위험도}) / \text{적용 전 위험도} \times 100\%$
보안 사고 감소율	통제 적용 후 보안 사고 감소 비율	$(\text{적용 전 사고 수} - \text{적용 후 사고 수}) / \text{적용 전 사고 수} \times 100\%$
직원 인식도	보안 정책 및 절차에 대한 직원 인식 수준	설문조사, 모의훈련 등을 통한 측정
규정 준수율	보안 정책 및 절차 준수 비율	내부 감사를 통한 측정

4.3 주기적 검토 및 개선

활동	주기	담당자	내용
통제 효과성 검토	반기 1회	보안담당	구현된 통제의 효과성 평가
위험 재평가	연 1회	보안담당, 자산 소유자	자산별 위험 재평가
통제 갱신	필요 시	보안담당, IT팀	효과가 부족한 통제 개선
정책 및 절차 검토	연 1회	보안담당, 법무팀	정책 및 절차 최신화
새로운 위협 대응	상시	보안담당	새로운 보안 위협에 대한 대응책 마련

5. 작성 예시

5.1 위험 처리 방안 결정 작성 예시

위험 ID	자산명	위험 등급	위험 도	처리전략	상세방안	구현일정	담당자	예산 (만원)	예상효과	승인 상태	승인자	승인 일자
RISK-001	신제품 설계도면(P-2025-01)	상 (High)	50.4	위험 감소 (Risk Reduction)	1) 설계도면 DRM 적용	2025.07.01 ~ 2025.08.31	보안 담당 권세창	300	위험도 50.4 → 15.0 (감소율 70%)	승인	이성영	2025.06.10
					2) 네트워크 접근통제 강화							
					3) 직원 보안교육 실시							
RISK-002	PLM 시스템(설계개발)	상 (High)	72	위험 감소 (Risk Reduction)	1) PLM 시스템 보안패치 적용	2025.06.15 ~ 2025.07.31	전산 팀 권세창	500	위험도 72.0 → 25.0 (감소율 65%)	승인	이성영	2025.06.10
					2) 이중인증 도입							
					3) 권한 관리 체계 구축							

5.2 핵심 문서 통제 이력 관리 작성 예시

문서 ID	문서명	문서 유형	보안 등급	중요도점수	소유 부서	관리자	핵심문서여부	선정사유	적용통제 방안	상태	특이사항
EDM-001	신제품 설계도면(P-2025-01)	설계도면	극비	8.8	설계팀	김종훈	예	신제품 핵심 기술정보 포함	DRM, 접근권한관리, 암호화	정상	DRM 적용 완료
EDM-002	고객승인 서류(현대차)	승인 서류	극비	8.3	원가 영업실	조효제	예	주요 고객 계약 관련 문서	접근권한 관리, 워터마킹, 추적	정상	워터마킹 설정 완료

5.3 문서 관리 점검 체크 리스트 작성 예시

점검 구분	점검 항목	점검 기준	점검 방법	적합 여부	미적합 여부	개선사항
문서 분류	문서 분류 기준표 작성 및 적용	분류 기준표가 수립되고 일관되게 적용되는가?	문서 검토	☐ 적합	☐ 미적합	
문서 분류	문서 유형별 적절한 분류 실시	문서 유형에 따라 적절히 분류되었는가?	문서 검토	☐ 적합	☐ 미적합	
중요도 평가	중요도 평가 기준 적용	중요도 평가 기준이 문서화되고 적용되었는가?	문서 검토	☐ 적합	☐ 미적합	

6. 문서 관련 주요 보안 솔루션

솔루션 유형	주요 기능	도입 고려 사항
DRM(Digital Rights Management)	- 문서 암호화 - 접근 통제 - 사용 제한(읽기, 편집, 인쇄) - 만료 설정	- 사용자 편의성 - 시스템 호환성 - 관리 용이성
DLP(Data Loss Prevention)	- 데이터 유출 탐지 - 정책 기반 차단 - 모니터링 및 보고	- 오탐률 - 성능 영향 - 관리 복잡성
ECM(Enterprise Content Management)	- 문서 중앙화 - 버전 관리 - 워크플로우 - 접근 통제	- 기존 시스템 통합 - 사용자 교육 - 마이그레이션 비용
EDRM(Enterprise Digital Rights Management)	- 기업 전체 DRM 관리 - 통합 정책 적용 - 중앙 모니터링	- 구축 비용 - 관리 인력 - 사용자 수용성

7. 주의사항

- 통제 방안은 비즈니스 요구사항과 균형을 이루어야 합니다. 과도한 통제는 업무 효율성을 저해할 수 있습니다.
- 모든 통제 방안은 정기적으로 효과성을 검토하고 필요 시 개선해야 합니다.
- 통제 방안 적용 시 사용자 교육과 인식 제고가 중요합니다.
- 신기술 도입 시 발생할 수 있는 새로운 위험에 대비하여 통제 방안을 지속적으로 업데이트해야 합니다.
- 비용 대비 효과를 고려하여 적절한 통제 방안을 선정해야 합니다.